壁垒WAF（BILEI WAF）

内蒙古勤加软件有限公司

2026 年 10 月 · 版本 v1.0.5

内蒙古勤加软件有限公司 · © 2026 版权所有

目 录

1 项目背景 3

1.1 Web 安全面临的现实挑战 3

1.2 我们的目标 3

2 作品概述 3

3 技术架构 3

3.1 总体架构 4

3.2 请求检测流水线 4

3.3 AI 引擎 4

3.4 可靠性工程 4

4 核心功能 5

5 关键创新点 5

6 应用场景 6

7 开源与社区 6

8 检测能力实测（blazehttp 全量回放） 6

9 参赛材料清单 6

开源智能 Web 应用防火墙 · 第四届开放原子大赛 2026 开源行业解决方案创新赛（赛道一）作品介绍

参赛单位：内蒙古勤加软件有限公司 | 版本：v1.0.5 | 2026 年 10 月

> 代码仓库：Gitee https://gitee.com/qinpluscom/bileiwaf ｜ GitHub https://github.com/qinplus-com/bileiwaf

> 演示视频：《壁垒WAF-比赛演示.mp4》随作品材料一并提交

---

1 项目背景

1.1 Web 安全面临的现实挑战

Web 应用是政企对外服务的第一入口，SQL 注入、命令注入、SSRF、XXE 等经典攻击至今仍占据 OWASP 攻击统计的主体。中小企业与基层政务单位在部署 WAF 时普遍面临四个痛点：

1. 性能与成本矛盾：基于脚本/规则解析的传统 WAF
   在高并发下资源占用高，小型机构买得起硬件、养不起性能；
2. 规则滞后与误报两难：纯规则引擎对新型攻击payload
   检出滞后，放宽规则又推高误报率，业务方被迫"带病上线"或"一关了之"；
3. AI 与规则割裂：多数 AI
   检测方案独立于规则体系运行，缺乏可解释的联级机制，误报无法溯源、难以灰度；
4. 部署与可视化门槛高：配置复杂、缺乏直观的攻防视图，安全价值难以向管理层呈现。

1.2 我们的目标

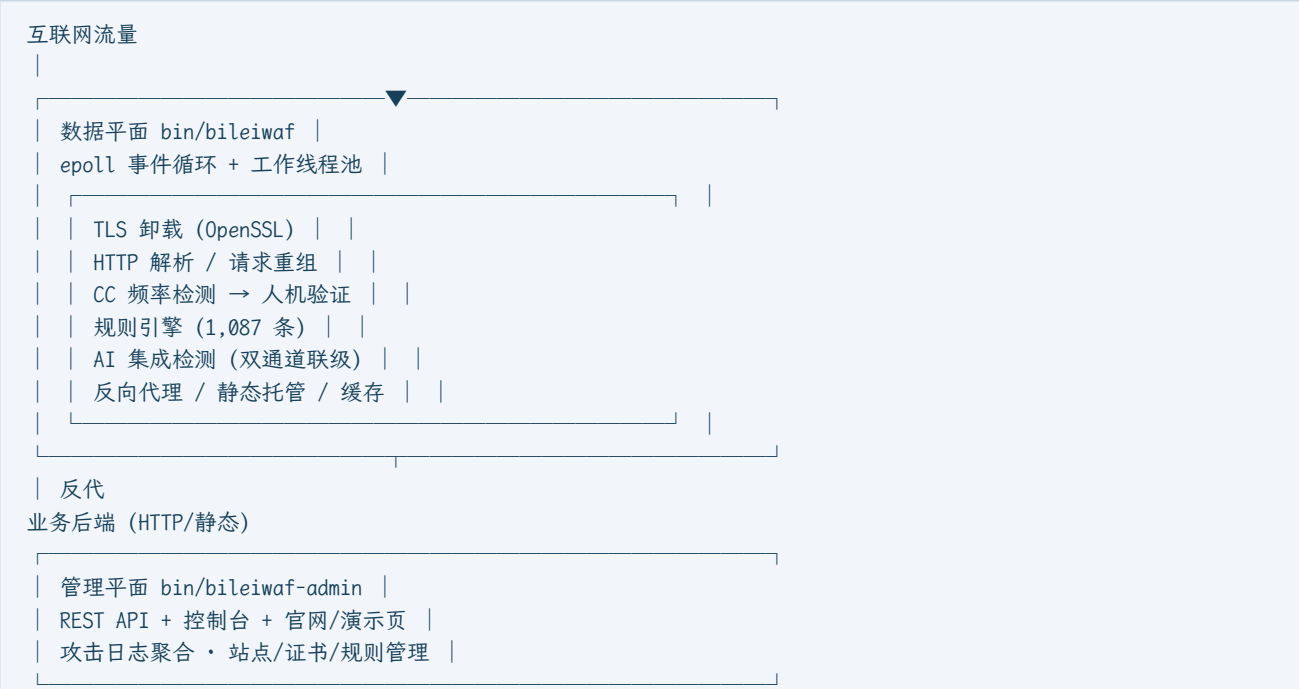
用一门"慢语言"做好一件"快事情"——以 C 语言打造单二进制、高性能、规则与 AI 双通道的反向代理型 WAF，让中小企业与基层单位以极低资源成本获得达到生产级检出率（≥ 99.8%）的 Web 防护能力，并通过全流量可视化让防护效果"看得见、验得着"。

2 作品概述

维度	说明
产品形态	反向代理型 WAF，由数据平面（检测/代理）与管理平面（控制台/官网/演示）组成
开发语言	C（C99），依赖 OpenSSL / libcurl / json-c，可选 libmaxminddb
检测体系	规则引擎（1,087 条内置规则）+ AI 集成模型（基于规则库蒸馏训练），三模式切换
部署方式	源码 `configure && make && make install` 或二进制发行包，支持 systemd 一键托管
核心指标	blazehttp 全量回放：检出率 99.70% · 误报率 0.09% · 综合准确率 99.903%；HTTP 处理 5,759 QPS，平均耗时 162.53 ms

3 技术架构

3.1 总体架构



两平面分离：数据平面专注于流量转发与检测，管理平面独立监听（默认 19000）提供登录鉴权后的管理能力，互不影响、可分别重启。

3.2 请求检测流水线

每个请求依次经过：

1. 接入层：TLS 卸载（支持 Let's Encrypt ACME 自动签发/续期与热加载）、HTTP 解析、限速（rate/burst）；
2. CC 防护：滑动时间窗统计单 IP 频率，超阈值返回 302 图形验证码（人机验证）或封禁；触发阈值的 IP 同时写入动态黑名单，期间全部请求直接 403，到期自动解封；
3. 规则引擎：按攻击类型分文件的 1,087 条规则（SQL 注入 297 / 命令注入 403 / SSRF 181 / XXE 120 / XSS 41 / 路径穿越 20 / 扫描器 18 / 上传 7），支持 IP/URL 白名单豁免；
4. AI 检测：auto 模式下 AI 先判，AI 未拦截的再走规则引擎联级复核——任一通道判定恶意即拦截；
5. 转发层：干净请求反代至业务后端或托管静态文件（含内存缓存、gzip）。

3.3 AI 引擎

- 蒸馏训练：AI 模型（`models/ai_cnn.dat`、`ai_ae.dat`、`ai_fusion.dat`，含 CNN / AE / Fusion 集成）基于规则库标注样本蒸馏训练，推理结果与规则语义对齐，可解释性强；
- fail-safe 兜底：纯 AI 模式下模型缺失或异常时自动回退规则引擎，防护永不空转；
- 影子模式：AI 只打分写日志不拦截，生产流量上先灰度验证再切流；
- AILEARN 护栏自主学习：AI 高分但规则未拦的载荷自动聚类铸造新规则，铸造前对白名单全量评估，产生任何误报即拒绝落盘——把"AI 学到的"沉淀为"可审计的规则"。

3.4 可靠性工程

- 连接队列上限保护（4096），防止 accept 速率过快耗尽文件描述符；

- 崩溃自诊断：信号处理器内仅使用 async-signal-safe 调用，记录故障信号、指令地址与调用帧链到 `waf-crash.log`，保证进程必然终止并被 systemd 拉起（杜绝"活着但全员挂起"）；
- 规则与证书 SIGHUP 热加载，升级配置不中断业务；
- 站点日志按大小滚动，管理操作全量审计。

4 核心功能

功能域	能力
攻击防护	SQL 注入 / XSS / 命令注入 / 路径穿越 / XXE / SSRF / 恶意上传 / 扫描器识别 / CC 攻击 九类
工作模式	learning（学习）/ detection（检测告警）/ blocking（拦截）三模式
检测模式	rules / ai / auto 三通道，检测阈值可调
HTTPS	OpenSSL 卸载、Let's Encrypt 一键签发与续期、自签名生成、热加载
站点管理	多站点反代、静态托管、内存缓存、gzip、请求限速、自定义错误页
CC 防护	频率阈值 + 302 人机验证（验证码）+ 时限封禁 + IP 自动黑名单（动态拉黑、到期自动解封）
黑白名单	IP / URL 白名单豁免、IP 黑名单封禁（静态条目 + CC 联动动态条目，白名单优先）
可视化	管理大屏（今日攻击/本月拦截/本月攻击/本月请求/实时 QPS/全球态势，自然月口径、日志轮转不断档）、攻击日志多维检索、攻防演示页、blazehttp 报告页
GeoIP	攻击来源地理定位（libmaxminddb，可选）
告警审计	攻击日志、管理审计日志、AI 影子日志

5 关键创新点

1. 规则 + AI 双通道联级架构（auto 模式）：AI 先判、规则复核，两通道语义对齐（AI 由规则库蒸馏训练而来）。实测在 33,877 条真实流量样本上实现 99.70% 检出率与 0.09% 误报率的兼得——AI 补拦 11 个规则漏报样本且不新增误报。
2. AILEARN 护栏自主学习：业内常见的"AI 自动学"极易引入误报。本作品将 AI 高分未拦载荷聚类铸造为新规则，且铸造前必须通过白名单全量评估——学习产物是可审计、可回滚的规则文本，而非黑盒模型更新。
3. C 语言单二进制数据平面：epoll + 线程池 + 无 GC 运行时，5,759 QPS / 平均 162.53 ms 的实测吞吐，2 GB 内存小机即可承载，适配基层单位存量硬件。
4. fail-safe 工程化 AI：模型缺失回退规则兜底、影子模式灰度、阈值保守可调——AI 增强而不是绑架检测链路。
5. 全链路可视化与攻防实证：内置攻防演示页（浏览器一键发起真实攻击、实时观察 403/200）、全球攻击态势大屏、blazehttp 报告页，防护效果全程可验证、可展示。
6. 生产级可靠性细节：连接队列上限防 fd 耗尽、async-signal-safe 崩溃自诊断、规则/证书热加载，均为真实事故驱动的工程修复。

6 应用场景

场景	说明
中小企业网站/API 防护	反代接入即防护，无需改造业务代码；2 GB 小机即可部署
多站点统一防护	多站点配置统一管理，域名/证书/日志集中运维
政务与等保合规建设	攻击拦截留痕、审计日志、可视化大屏支撑安全运营与等保材料
防爬虫与防薅羊毛	CC 频率检测 + 人机验证 + 限速组合
安全教学与实训	攻防演示页与 curl 验证命令构成开箱即用的教学环境
国产化/低资源环境	C 语言 + 标准依赖库，适配国产 Linux 发行版与存量硬件

生产案例：作品已在 dbask.cn 等多个站点生产运行（HTTPS + Let's Encrypt 自动续期 + CC 人机验证 + 多站点统一接入），并经受持续的真实互联网流量考验。

7 开源与社区

- 代码仓库：Gitee https://gitee.com/qinpluscom/bileiwaf ｜ GitHub https://github.com/qinplus-com/bileiwaf
- 开源协议：Apache License 2.0
- 版本计划与生命周期：采用 semver；当前 1.0.x 稳定维护版全量支持，1.1.0（IPv6、REST API 告警订阅）、1.2.0（规则市场与社区共建规则集、容器化部署模板、多节点配置同步）规划中；上一个次版本提供 6 个月安全修复，更早版本 EOL。详见仓库 README「版本计划与生命周期」。

欢迎通过 Issue 反馈漏洞与误报样本，通过 PR 提交规则与功能改进；误报/漏报样本将用于规则修正与 AI 蒸馏语料迭代。

8 检测能力实测（blazehttp 全量回放）

评测方法：blazehttp 开源评测框架，全量回放真实流量样本（恶意样本 658、白样本 33,219）。

指标	rules 模式	ai 模式	auto 模式
检出率	98.02%	93.77%	99.70%
误报率	0.09%	0.00%	0.09%
综合准确率	99.870%	99.879%	99.903%

auto 相对 rules 漏报数由 13 降至 2（AI 补拦 11 个漏报样本），误报数保持 31 不变。

基线对比（相同样本）	检出率	误报率	综合准确率
壁垒WAF v1.0.5（auto）	99.70%	0.09%	99.903%
壁垒WAF v1.0.5（rules）	98.02%	0.09%	99.870%
ModSecurity OWASP CRS（PL1 平衡）	69.74%	17.58%	82.20%
ModSecurity OWASP CRS（PL4 严格）	94.61%	52.46%	48.34%

性能：HTTP 处理 5,759 QPS，平均耗时 162.53 ms（8 工作线程实测）。详细评测见作品附带《检测能力验证报告》页（`/report.html`）。

9 参赛材料清单

材料	说明
代码仓库	Gitee https://gitee.com/qinpluscom/bileiwaf（主） | GitHub https://github.com/qinplus-com/bileiwaf（镜像）
作品介绍文档	本文档（PDF）
作品演示视频	《壁垒WAF-比赛演示.mp4》（1 分 43 秒，含登录、攻击拦截、管理能力、监控大屏全流程实拍），随作品材料一并提交
演示文稿	《壁垒WAF-参赛作品演示.pptx》（含全部页面截图）
安装手册 / 使用手册	随作品提交，仓库 `docs/` 目录同步提供

内蒙古勤加软件有限公司 · © 2026 版权所有